BRIEFINGS

black hat

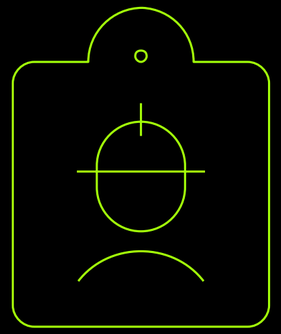
black hat SECTOR 2026

READ THE PLANT LIKE A BLUEPRINT

The Quiet Protocol Running Critical Infrastructure in Industry 4.0

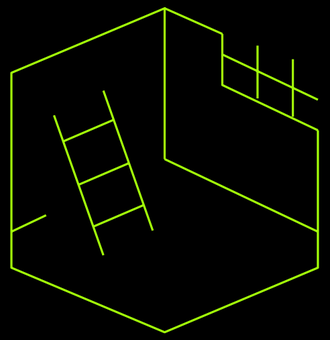
Juned Ahmed Ansari
Unit 42, Palo Alto Networks | Black Hat SecTor 2026

$ WHOAMI



The Day Job

Principal Consultant – Unit42 OffSec Team



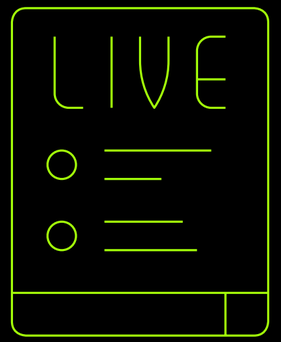
The Obsession

Honeypots that don't look like honeypots



Habitat

Dubai, EMEA



Mileage

12+ years breaking OT, from oil and gas to a air traffic control

Information Classification: General

FROM THE RED TEAM SIDE

Every OT red team used to dead-end at a proprietary protocol I had to reverse. Now it ends at OPC UA, and I already speak it.



THE CONSTANT

OPC UA now shows up on nearly every converged OT estate I assess: oil and gas, water, substations.



THE EASE

A single unauthenticated Browse returns the whole plant. No reverse engineering, no tribal knowledge.



THE QUESTION

So once the report is written, what do I actually tell the client to do about it?

Information Classification: General

THE BARRIER JUST DROPPED



ENUMERATE

- Point a model at the public spec.
- It writes the discovery and Browse loop in one pass.



AUTHENTICATE

- Anonymous, or a seeded credential.
- The model handles the session handshake.



READ

- Pull every live value and days of history.
- One generated loop, no OT knowledge.

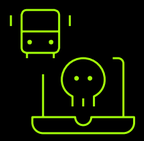


WRITE

- Set a point.
- Call a method.
- The model never asks whether it is a live plant.

Information Classification: General

WHAT WE'RE COVERING



01 The Attack Surface

OT infra 101 + Purdue model;

Where OPC UA fits;

Protocol architecture & message layers;

Discovery, handshake, and protocol abuse.



02 The Tool - OpcUaTrap

Why high-interaction , Architecture & LibUA stack

Address space realism

Honeytoken methodology

Threat scoring + NDJSON logging.



03 The Demo

basic enumeration

honeytoken trigger

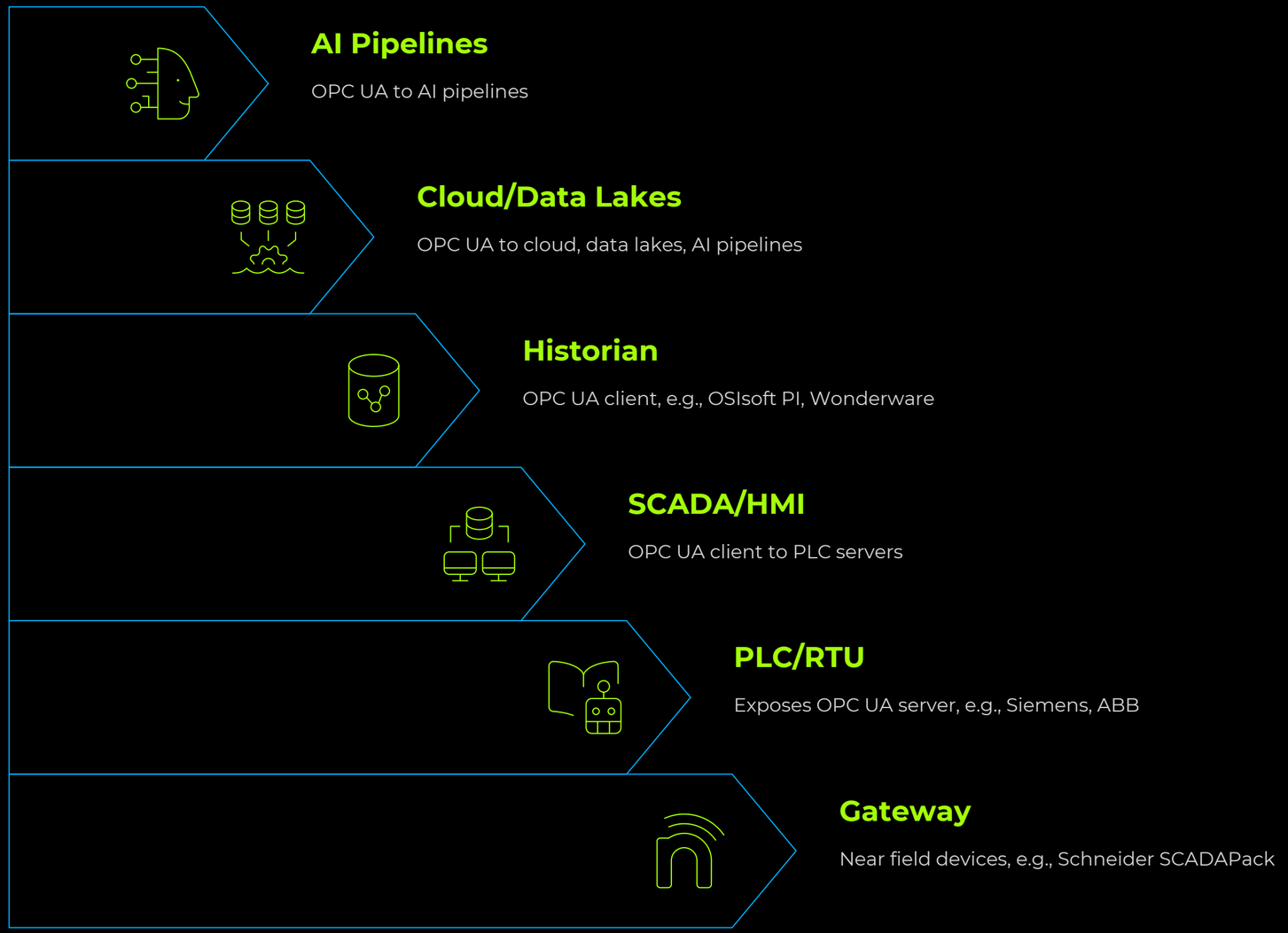
OpalOPC vuln scan

simulated MOUSEHOLE chain

Information Classification: General

THE ATTACK SURFACE

WHERE OPC UA FITS



From a Level 3 historian protocol to a vertical bridge spanning Levels 1 through 5.

OPC UA is the only protocol stretching from a sensor reading to an executive's dashboard — that's why it's the universal target.

Information Classification: General

USE CASE - OIL & GAS PRODUCTION

Where OPC UA aggregates wellhead, separator, and pipeline telemetry into a single pane of glass.



Wellheads / RTUs

Schneider SCADAPack, Emerson FloBoss



Separators / Pipelines

Pressure, level, flow telemetry



OSIsoft PI Historian

OPC UA client, 30-day retention



Cloud / AI analytics

Predictive maintenance, ESG reporting

REFERENCE DEPLOYMENT

Equinor Johan Sverdrup

Largest documented upstream OPC UA deployment on record. Real-time cloud data flow from offshore platform to onshore operations centre.

ref: github.com/equinor/opc-ua-information-models · TGS / Aker BP case study (tgs.com)

1.2 M

mapped variables

150 K objects · multi-vendor

Information Classification: General

USE CASE - MUNICIPAL WATER TREATMENT

Where OPC UA bridges legacy PLCs to modern SCADA — and where weak auth is the rule, not the exception.



Raw Water Intake

Pumps, turbidity, pH



Coagulation / Floc

Alum dose, polymer feed



Sedimentation

Basin levels, sludge



Disinfection

Cl2 dose, chloramine



Distribution SCADA

High-service pumps, zones

TYPICAL ENVIRONMENT

- Allen Bradley + Siemens PLCs
- OSIsoft PI or Wonderware Historian (often older versions)
- Contractor-managed, often unattended
- Default credentials, weak / no segmentation

WHY THIS USECASE EXISTS

- Every stage of a water plant has at least one writable setpoint that, if changed badly, doesn't crash anything visible — it just slowly degrades water quality over hours or days. That's the danger. It doesn't look like an attack. It looks like the plant is having a bad week.

Information Classification: General

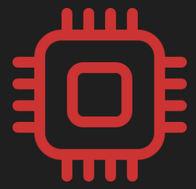
USE CASE - POWER GRID SUBSTATION

Where OPC UA + IEC 61850 form the substation-automation backbone — and where NERC CIP creates the strictest hardening requirement.



138 kV Substation

Transformers · breakers · CAP banks



RTU / Protection Relays

ABB RTU560, SEL-351/387/421



Distribution Feeders

Reclosers, feeder current/MW



EMS / Control Centre

OPC UA + IEC 61850 to SCADA

REGULATORY POSTURE

NERC CIP-005 / CIP-007

Mandatory access control, electronic security perimeter, and audit logging on Bulk Electric System assets. OPC UA endpoints in transmission substations must enforce strict authentication.

KEY ATTACK TARGETS

- CB_*_CMD_TRIP — circuit breaker trip command
- REL_*_ENABLED — protection relay disable flags
- T_LTC_TAP_RAISE/LOWER — transformer tap changers
- 86 LOCKOUT — trip-all-breakers method

Information Classification: General

OPC CLASSIC VS OPC UA

Why the "UA" is not a version bump — it's a different protocol, by design.

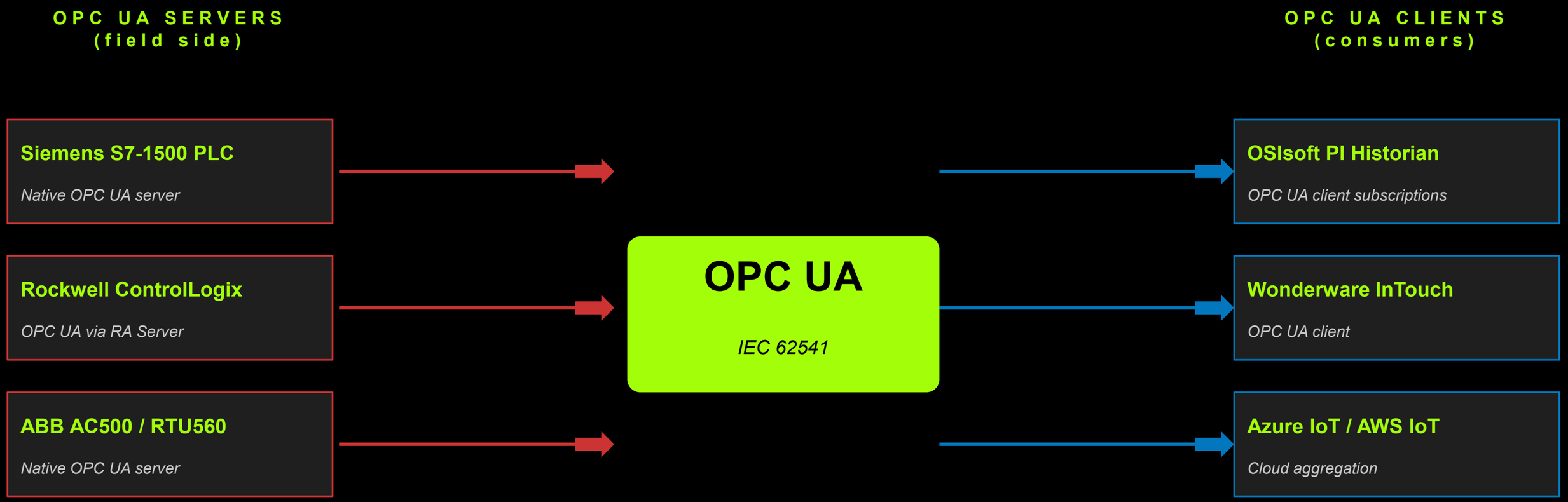
	OPC Classic	OPC UA (IEC 62541)
Protocol	DCOM / RPC / COM (Microsoft)	OPC UA Binary over TCP, plus HTTPS / WS
Transport	Windows RPC ports (dynamic)	Single, predictable port: TCP/4840
Architecture	Windows-only, registry-based	Service-oriented, cross-platform
Era	1996 – 2006	2008 – present
Standard	Proprietary Microsoft stack	ISO/IEC 62541
Security	Windows ACLs only	Built-in: SecurityModes, SecurityPolicies, X.509
Data semantics	Tag = numeric register index	Self-describing nodes (DisplayName, Type, EU, Range, alarms)
Interoperability	Vendor-locked over RPC	Multi-vendor by design — "the universal translator"

OpcUaTrap targets OPC UA only. It will NOT catch OPC Classic / DA attackers, and vice versa — different attack surfaces, different tooling.

Information Classification: General

OPC UA: THE UNIVERSAL TRANSLATOR

Multi-vendor by design — the lingua franca of converged industrial environments.



Information Classification: General

THE AI MANDATE

How the boardroom forced OPC UA into Level 0 — and why that matters for security.

BUSINESS PUSH

Boardroom wants Level 0 data

- Predictive maintenance, anomaly detection, digital twins — all need raw sensor data, not aggregated KPIs.
- GenAI / agentic systems plug directly into operational data lakes.
- OPC UA's self-describing nodes (DisplayName, Type, EU, Range, Alarm) are AI-pipeline ready out of the box.
- Result: vendor pressure to expose deeper layers of the address space, with fewer access controls in the way.

SECURITY IMPLICATION

Same metadata, different reader

- An OPC UA Browse on a refinery returns: "SEP_HP_201_PSP_2001 — High-Pressure Separator Pressure Setpoint, units PSI, range 0–1250."
- An adversary doesn't need to reverse-engineer the tag database. The protocol describes itself.
- Pre-Industry-4.0 ICS attacks required deep tribal knowledge. Now they require an unauthenticated Browse.
- OPC UA is the most well-documented attack surface in OT — by design.

The semantic richness that makes OPC UA valuable to AI pipelines makes it valuable to adversaries.

Information Classification: General

PROTOCOL ARCHITECTURE & ATTACK SURFACE

ACT 02

Discovery, handshake, message layers — and where each one breaks.

Information Classification: General

OPC UA PROTOCOL LAYERS

From TCP socket to service call — what an attacker actually touches.

Service Set	Browse · Read · Write · Call · CreateSubscription · HistoryRead - the application semantics.
Session Layer	CreateSession · ActivateSession - bound to a SecureChannel.
Secure Channel	OPN - symmetric key exchange, message signing, encryption.
Connection	HEL · ACK - protocol version, message size negotiation.
Transport	TCP / TLS on TCP/4840 · Or HTTPS / WebSocket variants.

ATTACK SURFACE

SERVICE

Write injection, method call abuse, bulk Read/HistoryRead exfil.

SESSION

Anonymous auth, weak credentials, session hijacking.

CHANNEL

Open-channel flooding (CVE-2023-32787 class).

CONN.

Malformed HEL — pre-auth crash.

TRANSPORT

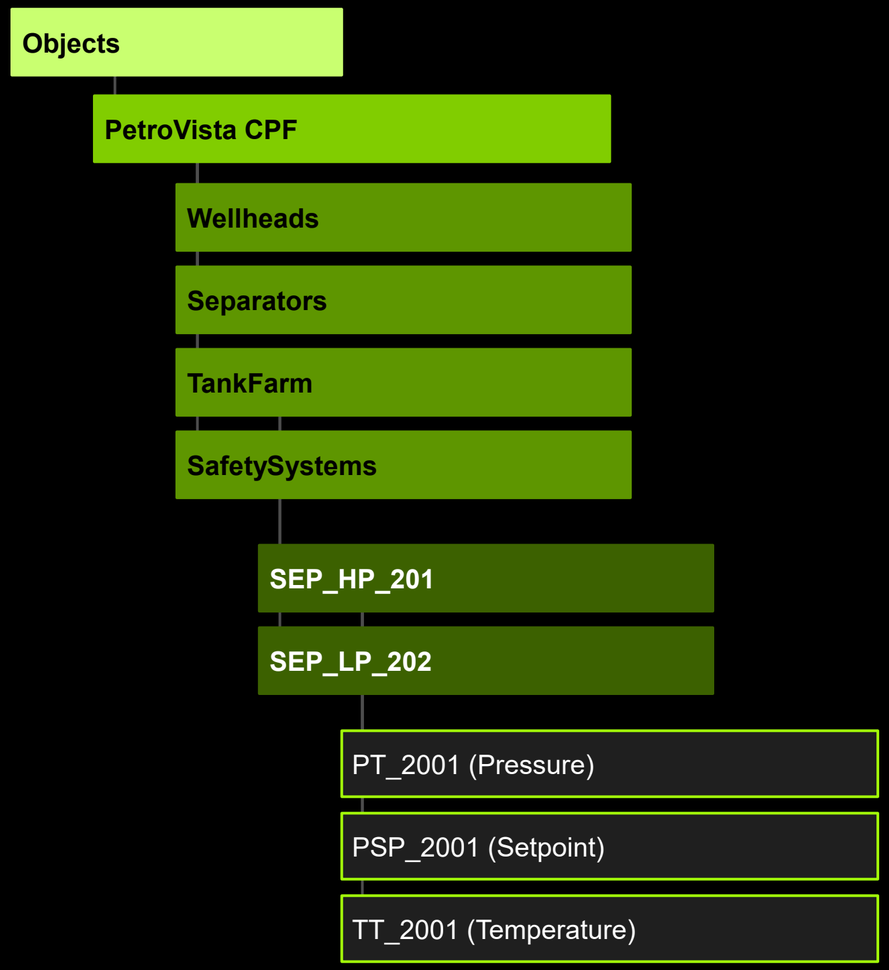
TLS misconfig, cert validation bypass, MITM.

Each layer has its own pre-auth attack surface. None require credentials.

Information Classification: General

OPC UA ADDRESS SPACE

Self-describing nodes. The thing that makes OPC UA powerful — and the thing that makes it leaky.



A single Variable Node carries:

NodeId	ns=2;s=SEP_HP_201_PSP_2001
DisplayName	HP Separator Pressure Setpoint
Description	Operator-adjustable target pressure for HP separator vessel
DataType	Double
EngineeringUnits	PSI
EURange	0.0 … 1250.0
AccessLevel	CurrentRead | CurrentWrite | HistoryRead
Alarm Refs	→ HighAlarm @ 1200, → HighHighAlarm @ 1240

An unauthenticated Browse + Read returns this entire structure. No reverse-engineering required.

Information Classification: General

OPC UA IN PLAIN ENGLISH

Stop thinking 'industrial protocol'. Start thinking 'website'.

If you know...	...then OPC UA's version is...	What an attacker does
Web server	**OPC UA server (in/next to PLC, RTU, gateway)**	Scan tcp/4840 — same as scanning tcp/80
URL / path	**NodeId (e.g. ns=2;s=ESD_CMD_TRIGGER)**	Browse like crawling sitemap.xml
GET request	**Read service**	Pull every value visible to the session
POST / PUT request	**Write service → setpoint, command, alarm threshold**	Same risk as IDOR + missing auth in a web API
RPC / API endpoint	**Call service → ESD_CMD_TRIGGER, breaker trip**	Method calls = remote actions on physical equipment
WebSocket / SSE	**CreateSubscription → live tag updates**	Real-time process telemetry stream
Site search / sitemap	**GetEndpoints + recursive Browse**	Free, unauth address-space map

If you've ever pentested a web app, you already understand 80% of OPC UA — the protocol is just HTTP for industrial sensors.

Information Classification: General

OPC UA SECURITY MODEL

Three modes. Six policies. Three auth schemes. The combinations matter.

SecurityMode

- 🔴 **None**

  No signing, no encryption. Cleartext traffic.

- 🟡 **Sign**

  Messages signed but readable. Tamper-evident.

- 🟢 **SignAndEncrypt**

  Full confidentiality + integrity.

SecurityPolicy

- 🔴 **None**

  No crypto at all.

- 🔴 **Basic128Rsa15**

  Deprecated. RSA PKCS#1 v1.5.

- 🔴 **Basic256**

  Deprecated. SHA-1 based.

- 🟡 **Basic256Sha256**

  Common baseline. AES-256 + SHA-256.

- 🟢 **Aes128_Sha256_RsaOaep**

  Modern. RSA-OAEP padding (preferred).

- 🟢 **Aes256_Sha256_RsaPss**

  Strongest. RSA-PSS.

Authentication

- 🔴 **Anonymous**

  No identity check.

- 🟡 **Username/Password**

  Cleartext if SecurityMode=None.

- 🟢 **X.509 Certificate**

  Mutual auth. Trust list required.

🔴 Insecure / deprecated 🟡 Acceptable / context-dependent 🟢 Recommended

Information Classification: General

DISCOVERY & HANDSHAKE ABUSE

Local Discovery Service — full security characterisation, no credentials needed.

LDS enumeration flow

1. **Connect TCP/4840**

   No auth, no cert. Just open the socket.

2. **FindServers()**

   Returns ApplicationName, ApplicationUri, ProductUri.

3. **GetEndpoints()**

   Returns ALL exposed endpoints with their SecurityMode and SecurityPolicy.

4. **Pick weakest**

   Adversary now knows the cryptographic posture before authenticating.

python — asyncua — no credentials

```python
from asyncua import Client

c = Client('opc.tcp://target:4840')
await c.connect()

# Enumerate endpoints — no auth needed
endpoints = await c.get_endpoints()

for ep in endpoints:
    print(ep.SecurityMode,
          ep.SecurityPolicyUri)
```

→ Result: full enumeration of allowed crypto.

```
MessageSecurityMode.None
MessageSecurityMode.Sign + Basic256Sha256
MessageSecurityMode.SignAndEncrypt + Basic256Sha256
MessageSecurityMode.SignAndEncrypt + Aes128_Sha256_RsaOaep
```

Information Classification: General

SECURITYMODE NONE — THE OPEN DOOR

The single highest-leverage configuration choice in OPC UA security.

SecurityMode = None

⛔ THE OPEN DOOR

- Read entire address space — no auth
- Write to any writable node — no auth
- Call methods (incl. ESD trigger) — no auth
- Subscribe to any tag — no auth
- Read 30+ days of history — no auth
- Cleartext on the wire — passive sniffing yields all the above + values

SignAndEncrypt + X.509

✓ THE LOCKED DOOR

- Mutual cert authentication — server validates client identity
- All messages signed — tamper-evident
- All messages encrypted — passive sniffing yields nothing
- Trust list required to add new clients — supply-chain control
- Blocks the entire MOUSEHOLE chain at the discovery step
- Single config flag in most servers — disable None policy

Shodan routinely finds OPC UA servers with None/None on the public internet. This is not theoretical.

Information Classification: General

THREAT INTELLIGENCE

ACT 03

Who's actually using OPC UA as an attack surface — and what it looks like in the wild.

Information Classification: General

CHERNOVITE - PIPEDREAM

The first nation-state malware framework purpose-built for ICS — with a dedicated OPC UA module.

THE ACTOR

CHERNOVITE

Nation-state activity group. Pre-positioning for disruptive operations against energy infrastructure (Dragos attribution).

- First confirmed ICS-purpose-built framework
- Disclosed: April 2022 (CISA AA22-103A)
- Seven distinct modules in the framework
- Targets: Schneider PLCs · Omron PLCs · OPC UA
- OPC UA module — codename MOUSEHOLE

PIPEDREAM — the framework

MOUSEHOLE	OPC UA — universal target
EVILSCHOLAR	*Schneider Modicon (M340/580)*
BADOMEN	*Schneider TM221*
DUSTYMARKER	*Omron PLCs*
LAZYCARGO	*Omron — drives PLC firmware*
LIGHTSWITCH	*(supporting modules)*

MOUSEHOLE = the OPC UA arm. The next slide is the entire attack chain — with each step mapped to an OpcUaTrap detection rule.

Information Classification: General

THE RECOMMENDATION GAP

The standard advice is correct, slow, and not enough on its own.

WHAT WE USUALLY WRITE

- Patch the OPC UA stack
- Enforce SignAndEncrypt, retire SecurityMode None
- Broker all traffic at the IT / OT DMZ
- Least privilege per client and per node

WHY IT IS NOT ENOUGH

- OT patch cycles lag years behind disclosure
- You cannot remove OPC UA, the business runs on its data
- Segmentation is partial, and you learn it failed after the fact
- None of it tells you an operator is already on the wire

Information Classification: General

THE ANSWER: DECOYS AND TRAPS

If the reconnaissance is automated, give it something built to be found.

INVERT THE ASYMMETRY

Prevention has to be right every time. A decoy only has to be convincing once.

MAKE THE AI TAKE THE BAIT

Automated, LLM-driven recon does not question a realistic address space. It enumerates, writes, and records itself doing it.

A SIGNAL YOU CAN ACT ON

Nothing legitimate ever connects to the decoy. Any touch is an operator, by definition. Near-zero false positives.

That is why I built OpcUaTrap. The rest of this talk is how it works.

Information Classification: General

OPCUATRAP

WHY A HONEYPOT? - THE OT DETECTION GAP

OT environments can't run inline IDS. Active defence is what's left.

THE PROBLEM

You can't put a firewall inline

An OT firewall that drops a packet at the wrong moment trips the breaker. Ten milliseconds of latency on a protection-relay path can cause arc flash. Inline blocking is operationally unacceptable in most plants.

PLCs and RTUs log nothing useful

Vendor-default logging is start/stop events and firmware updates. No record of unauthorised Browse, no record of who tried to write to ESD_CMD_TRIGGER, no record of credential brute-force. The PLC has no idea it was probed.

Passive monitoring misses pre-attack recon

Network DPI sees TCP/4840 traffic. It can't tell you 'this client just enumerated 143 nodes' vs 'this is a normal historian poll'. Both look identical on the wire. CHERNOVITE-class actors look like normal traffic.

OPC UA spec mandates unauth discovery

FindServers and GetEndpoints are spec-required to be unauthenticated. You cannot block them without breaking the protocol. The reconnaissance phase is built into the standard.

ACTIVE DEFENCE — THE ANSWER

Deception-driven detection. Engage the attacker on infrastructure designed to be observed — not blocked.

Don't block — observe

The honeypot accepts the attack and records it. Real plant assets are unaffected. No operational risk.

High-fidelity signal

Any connection to the honeypot is by definition out of place. Near-zero false positives. Compare to network DPI.

Pre-positioned in DMZ or PCS

Sits where lateral movement happens. Catches the attacker BEFORE they reach the real PLCs.

Information Classification: General

DESIGN PHILOSOPHY

Four design decisions, each traceable to a threat research finding.

01 · INTERACTION DEPTH

High interaction

Full OPC UA protocol compliance - not a banner-grabbing port listener. Real Browse, Read, Write, Call, Subscribe, HistoryRead. The deception is in what happens next, not in the handshake.

02 · REALISM

Live process simulation

~120 process variables on a 1-second tick. Gaussian noise, mean-reverting drift, tank fill/drain dynamics. A static address space is fingerprinted in seconds.

03 · STACK CHOICE

Built on LibUA (.NET)

Open-source full OPC UA stack. Minimal abstraction so we own every operation handler..

04 · WRITE DECEPTION

Writes return Good — values revert

All writes succeed from the attacker's view. Values revert to simulated state in 1 second. Method calls (ESD, lockout) succeed silently. They have no signal the attack failed.

Every design choice maps to an attacker behaviour we want to observe — not a feature for its own sake.

Information Classification: General

OPCUATRAP ARCHITECTURE

Component view — from network packet to SIEM event.

Network Layer	OPC UA Stack	Honeypot Logic	Logging Fan-out
tcp/4840 listener *OPC UA Binary*	**LibUA .NET** *Full stack*	**ProfileLoader** *JSON → AddressSpace*	**InteractionLogger hub** *Fan-out to N sinks*
TLS / SecureChannel *4 endpoints offered*	**HoneypotApplication** *All handlers overridden*	**SimulationEngine** *1s tick, drift, noise*	**NDJSON (always-on)** *Daily rotation*
Session lifecycle *Hello → Open → Activate*	**Cert auto-gen** *RSA 2048 / 3yr*	**TagClassifier + ScoreEngine** *12 detection rules*	**Syslog · CEF · Webhook · ES** *Pluggable SIEM*

A T T A C K E R → P R O T O C O L → D E C E P T I O N → A N A L Y S T

Information Classification: General

PROFILES - THREE PERSONAS, SAME BINARY

Everything below is configuration — facility name, address space, vendor identity, auth posture. JSON only.

PROFILE #1



Oil & Gas

PetroVista

Upstream CPF · 120 nodes · selective auth

PROFILE #2



Water Treatment

Cascade Municipal

Muni plant · 100 nodes · accept-all auth

PROFILE #3



Power Grid

Ridgeline 138 kV

Substation · 130 nodes · NERC posture

WHAT YOU CAN CHANGE BEFORE RUNNING — every value below is a JSON edit, no code

Facility identity	Address space	Vendor fingerprint	Auth posture
Plant name, location, ownership info, application-URI, server-URI	Node hierarchy, NodeIds, DisplayNames, EU ranges, alarm refs, methods	Advertised manufacturer + product (e.g. Rockwell ControlLogix 1756-L73)	Accept-all · selective · honeytoken seed list · rejected-credential list

Information Classification: General

PROFILE #1 · OIL & GAS — PETROVISTA CPF

The OpcUaTrap counterpart to slide 11. ~120 live process nodes modelling an upstream facility.

PetroVista Central Processing Facility

```
├── Site_Information/
├── Wellheads/
│     ├── WH_101 ── PT_1001 (pressure)
│     ├── WH_102, WH_103, WH_104 ...
├── Separators/
│     └── SEP_HP_201 ── PSP_2001 [PSP] ←
├── TankFarm/
│     └── TK_OIL_301 ── LAHH_3010 [LAHH] ←
├── PumpStations/
│     └── PMP_XFER_401 ── CMD_START ←
├── CompressorStation/
├── Pipelines/
│     └── PL_EXPORT_601 ── XV_6010 [XV] ←
├── SafetySystems/
│     ├── ESD/
│     │     ├── ESD_CMD_TRIGGER ←
│     │     └── ESD_CMD_RESET ←
│     └── FireAndGas/  (LEL detectors)
└── Utilities/
```

VENDOR IDENTITY (advertised)

"Schneider SCADAPack 57x RTU"

Standard upstream RTU. Common at wellheads / Equinor-class CPF deployments. Realistic O&G fingerprint.

AUTH MODE

SELECTIVE

Only seeded honeytoken accounts accepted. Matches well-regulated upstream operator posture.

Information Classification: General

PROFILE #2 · WATER TREATMENT — CASCADE MUNICIPAL

The OpcUaTrap counterpart to slide 12. ~100 nodes, accept-all auth — matches realistic muni water posture.

Cascade Municipal Water Treatment

```
├── Site_Information/
├── RawWaterIntake/
│     ├── INTAKE_PMP_101 ── CMD_START ←
│     └── TURB_101 (NTU)
├── Coagulation/
│     └── ALUM_DOSE_201 ── SP_GPM ←
├── Sedimentation/
│     └── BASIN_301_LVL
├── Disinfection/
│     ├── CL2_DOSE_401 ── SP_PPM ←
│     └── CL2_RESIDUAL_401 (Cl2 ppm)
├── DistributionSCADA/
│     ├── HSV_PMP_501 ── CMD_START ←
│     └── ZONE_A_PRESSURE
├── ChemicalStorage/
│     └── ALUM_TANK_LVL  ·  CL2_TANK_LVL
└── Utilities/
```

VENDOR IDENTITY (advertised)

"Rockwell ControlLogix 1756-L73"

Common in muni water; engineering-station fingerprint matches a typical mid-sized treatment plant.

AUTH MODE

ACCEPT-ALL

Any credential accepted. Honeytoken hits flagged. Realistic muni-water posture.

Information Classification: General

PROFILE #3 - POWER GRID — RIDGELINE 138 KV SUBSTATION

The OpcUaTrap counterpart to slide 13. ~130 nodes, selective auth — NERC CIP-realistic posture.

Ridgeline 138 kV Transmission Substation

```
├── Site_Information/
├── Transformers/
│     ├── T_BANK_1 — LTC_TAP_RAISE ←
│     └── T_BANK_1 — OIL_TEMP, GAS_DGA
├── CircuitBreakers/
│     ├── CB_138_1 — CMD_TRIP ←
│     ├── CB_138_2 — CMD_TRIP ←
│     └── CB_FDR_*  (12 feeders)
├── ProtectionRelays/
│     ├── REL_SEL421 — ENABLED ←
│     └── REL_SEL387 — ENABLED ←
├── DistributionFeeders/
│     └── FDR_*_AMPS, _MW
├── SafetySystems/
│     └── 86_LOCKOUT_RESET ←
└── Utilities/
```

VENDOR IDENTITY (advertised)

"ABB RTU560 Substation Gateway"

Standard transmission-substation gateway. SEL-class protection relays beneath. Matches a regulated BES asset.

AUTH MODE

SELECTIVE

Only seeded honeytoken accounts accepted. NERC-CIP-realistic posture. Bad creds rejected.

Information Classification: General

HONEYTOKEN CREDENTIALS — FIVE PERSONAS

Each pre-seeded credential signals a distinct attacker profile. Any other credential is also accepted — for dictionary capture.

Username	Password	Severity	Persona Tag	What its presence signals
admin	admin123	CRITICAL	*Default / weak*	Credential stuffing or default-hunting
engineer	Welcome1	CRITICAL	*Common enterprise*	Password-spray against known accounts
operator	op3rator!	HIGH	*Role-based, leet sub*	Targeted SCADA-specific list
svc_historian	h1st0rian	HIGH	*Service account format*	Targeted environment intelligence
readonly	readonly	MEDIUM	*Identical user/pass*	Automated, low sophistication

Any other credential is also accepted — and logged. The dictionary itself is intelligence about your attacker.

Information Classification: General

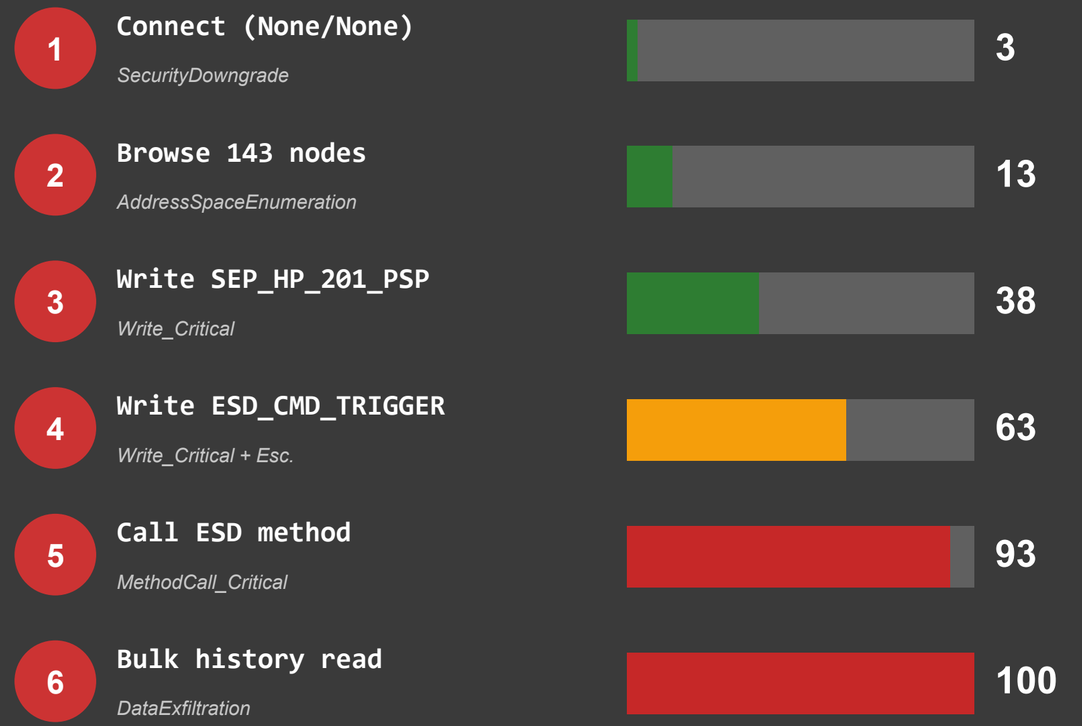
PER-SESSION THREAT SCORING

Composite 0–100 score builds across the session — distinguishes a passive scan from an operational attack chain.

DETECTION RULES — SCORE WEIGHTS

SecurityDowngrade	SecurityPolicy = None	+3
AddressSpaceEnumeration	> 100 Browse ops	+10
BulkReadExfil	> 20 nodes in one Read	+10
Write_Sensitive	Write to sensitive tag	+10
Write_Critical	Write to critical tag	+25
WriteEscalation	≥ 3 writes in session	+15
MethodCall_Critical	ESD / lockout method call	+30
SubscriptionCritical	Subscribe to critical tag	+20
HoneytokenLogin	Planted credential used	+15
DataExfiltration	> 1000 history points read	+10
CredentialSpraying	≥ 3 usernames from same IP	+15
RapidReconnection	≥ 3 connects from IP in 60s	+10

Simulated MOUSEHOLE attack — score progression



Real-world simulated attack chain → 100/100 in under 60 seconds.

Information Classification: General

STRUCTURED NDJSON LOGGING

Every event is a single JSON line — daily-rotated, thread-safe, SIEM-ready.

./logs/opcuatrap-2026-04-28.jsonl


```
{
  "timestamp": "2026-04-28T14:32:34Z",
  "operation": "WriteAttempt",
  "session_id": "a3f7c2d1",
  "source_ip": "10.20.30.45",
  "threat_score": 28,
  "profile": "oil-gas",
  "details": {
    "node_id": "SEP_HP_201_PSP_2001",
    "display_name": "HP Separator Pressure Setpoint",
    "attempted_value": "9999",
    "classification": "Critical",
    "severity": "CRITICAL"
  }
}
```


PLUGGABLE SIEM SINKS

NDJSON file

Always on · daily rotation

Syslog (RFC 5424)

UDP or TCP

ArcSight CEF

Over syslog transport

HTTP webhook

Severity-filtered POST

Elasticsearch

Direct bulk API

Information Classification: General

OPCUATRAP IN ACTION

LIVE DEMO

One honeypot. One attack script. Six attack phases.

- Setup
- Live Process
- Recon
- Full Attack Chain
- Logs
- Session Summary
- Profile Switch

Information Classification: General

DEMO - START THE HONEYPOT

Three terminals · honeypot impersonating a Rockwell ControlLogix at a water plant.

1

TOOL

```
dotnet run --profile water-treatment
```

COMMAND

```
# TERMINAL 1 — Start the honeypot server
cd c:\Tools\OpcUaTrap
dotnet run --project src/OpcUaTrap -- ^
    --profile water-treatment --port 4841

#   OpcUaTrap v0.4.0
#   OPC UA ICS/SCADA Honeypot
#
#   Profile: water-treatment
#     (Cascade Municipal Water Treatment Plant)
#   Server identity: AquaView SCADA Server
#   Listening on opc.tcp://0.0.0.0:4841
#   Vendor: Rockwell Automation
#           ControlLogix 1756-L73
```

EXPECTED OBSERVATIONS

OK	Server starts in <2s with realistic facility persona
OK	Vendor identity advertised: Rockwell ControlLogix 1756-L73
OK	Address space populated: ~100 nodes for Cascade Municipal
OK	Listening on tcp/4841 — full LibUA stack active

TAKEAWAY ***From the network's perspective, this IS a real water-plant SCADA server.***

Information Classification: General

DEMO - LIVE PROCESS DATA VIA UAEXPERT

What a real historian or HMI sees when it connects.

2 TOOL

UaExpert OPC UA client

COMMAND

```
# Connect UaExpert to opc.tcp://127.0.0.1:4841
# Accept the certificate
# Browse to:
#   Objects → Cascade Municipal Water Treatment Plant

# Drag these into Data Access View and watch them tick:
#   Raw Water Intake → River Intake Structure
#     → Raw Water Turbidity (NTU)        [fluctuates]
#   Disinfection → Primary Chlorination
#     → Chlorine Dose Setpoint (mg/L)    [WRITABLE]
#   Clear Well Storage → Clear Well 1
#     → Clear Well Level (ft)            [slow drift]
```

EXPECTED OBSERVATIONS

OK	Turbidity reads ~0.4 NTU and fluctuates with gaussian noise
OK	Chlorine dose setpoint reads ~2.8 mg/L (set point, writable)
OK	Clear well level slowly fills/drains — mean-reverting drift
OK	DataType, EngineeringUnits, EURange visible in node attributes

TAKEAWAY *If you wouldn't trust a real PLC's metadata, you wouldn't fingerprint this either.*

Information Classification: General

DEMO - RECONNAISSANCE PHASE

attack_simulation.py · phase 1 only · the attacker maps the entire facility.

3

TOOL

`attack_simulation.py --phase recon`

COMMAND

```
# TERMINAL 2 — Reconnaissance phase only
cd c:\Tools\OpcUaTrap\tools
uv run python attack_simulation.py ^
    --phase recon --port 4841

# T2 prints:
#   [*] Connecting to opc.tcp://127.0.0.1:4841 ...
#   [+] Server: AquaView SCADA Server
#   [+] Application: Cascade Municipal Water Authority
#   [*] Browsing folder tree...
#   [+] Raw Water Intake / Coagulation /
#       Filtration / Disinfection / ...
#   [*] 233 nodes discovered, 99 writable
#   [+] CRITICAL TARGETS table:
#       CL2_DOSE_SP_001  (Chlorine Dose) ← WRITE
#       INTAKE_PMP_*     (Pump commands) ← WRITE
```

EXPECTED OBSERVATIONS

DETECTION	T1: [BROWSE] AddressSpaceEnumeration · 143 ops · threatScore=10
DETECTION	T1: [READ] BulkReadExfil · 28 nodes · threatScore=20
DETECTION	T2: complete tag inventory printed — 233 nodes, 99 writable
DETECTION	T3 NDJSON: every Browse and Read logged with session ID

TAKEAWAY ***Recon completed in <30 seconds. Their session ID and full tag-touch trail is now logged.***

Information Classification: General

DEMO - FULL ATTACK CHAIN - 6 PHASES

attack_simulation.py runs the complete chain. Watch both terminals.

4

TOOL

attack_simulation.py — all phases

TIMING

~5 min · centerpiece

1 RECONNAISSANCE

Browse + Read: 233 nodes, 99 writable. Identify critical targets.

`AddressSpaceEnumeration`
`BulkReadExfil`

+10..+20

2 CREDENTIAL TESTING

Tries operator/op3rator!, admin/admin123, engineer/Welcome1.

`HoneytokenLogin`
`CredentialSpraying`

+15..+30

3 SAFETY DISABLE

Calls ESD_CMD_TRIGGER method. Server returns Good — they think it worked.

`MethodCall_Critical`

+30

4 PROCESS MANIPULATION

Writes pressure setpoint = 9999 PSI. Disables overflow LAHH.

`Write_Critical`
`WriteEscalation`

+25..+50

5 COVER TRACKS

Writes values back to normal. Critical-tag writes still flagged.

`Write_Critical (still fires)`

+25

6 DATA EXFILTRATION

Reads all variables + 30 days of history. 8640 history points.

`DataExfiltration`

+10

Run command: uv run python attack_simulation.py --port 4841 → final session score: 97/100 · 7 rules fired

Information Classification: General

DEMO - STRUCTURED LOGS & SESSION SUMMARY

Every action → one JSON line · session close → full attack profile.

5

TOOL

VS Code · NDJSON viewer · PowerShell tail

TIMING

~3 min

ONE CRITICAL WRITE — full structured event


```
{
  "timestamp": "2026-04-28T01:23:45Z",
  "operation": "WriteAttempt",
  "session_id": "a3f7c2d1",
  "source_ip": "127.0.0.1",
  "threat_score": 73,
  "profile": "water-treatment",
  "severity": "CRITICAL",
  "details": {
    "node_id": "CL2_DOSE_SP_001",
    "display_name": "Chlorine Dose Setpoint (mg/L)",
    "attempted_value": "0",
    "classification": "Critical"
  }
}
```


SESSION SUMMARY — on disconnect

```
operation = SessionClosed
session_id = a3f7c2d1
source_ip  = 127.0.0.1
duration   = 42s

browse=143  read=89  write=8  calls=1

threatScore = 97 / 100
severity    = CRITICAL

rules = [
  AddressSpaceEnumeration,
  HoneytokenLogin, CredentialSpraying,
  Write_Critical, WriteEscalation,
  MethodCall_Critical,
  DataExfiltration ]
```

TAKEAWAY

In 42 seconds: 7 detection rules fired, threat score 97/100. One JSON line per action — straight into your SIEM. The SOC has everything they need to open an incident.

Information Classification: General

DEMO - PROFILE SWITCH - SAME BINARY, NEW PERSONA

Stop the server. Restart with --profile power-grid. Substation in 5 seconds.

6

TOOL

`dotnet run --profile power-grid`

TIMING

~2 min

COMMAND

```
# TERMINAL 1 — stop current server
Ctrl+C

# Restart with the power-grid profile
dotnet run --project src/OpcUaTrap -- ^
    --profile power-grid

# Audience sees on restart:
#   Profile: power-grid
#     (Ridgeline 138kV Transmission Substation)
#   Server identity: Substation Gateway
#   Vendor: ABB RTU560 Remote Terminal Unit
#   Listening on opc.tcp://0.0.0.0:4840
#   Auth mode: SELECTIVE (NERC-CIP posture)
```

EXPECTED OBSERVATIONS

OK	New facility persona — ABB RTU560 substation gateway
OK	New address space — circuit breakers, transformers, protection relays
OK	Auth mode flips to SELECTIVE — bad creds now rejected
OK	Same binary · same detection rules · zero code changes

TAKEAWAY ***One JSON file changes everything: identity, address space, auth posture, vendor fingerprint.***

Information Classification: General

HARDENING — WHAT THIS MEANS FOR YOU

Practical controls aligned with CISA, NCSC, and IEC 62443.

PROTOCOL-SPECIFIC	ARCHITECTURAL	DETECTION
Mandatory: SecurityMode Sign or SignAndEncrypt Blocks the entire MOUSEHOLE recon chain in one control.	**DMZ brokerage at the IT/OT boundary** No direct OPC UA from enterprise to process control. Proxy everything.	**Deploy a honeypot in your DMZ** Any internal connection to it = lateral movement signal.
Policy floor: Basic256Sha256 Disable SHA-1 policies. Migrate to Aes256_Sha256_RsaPss where feasible.	**Micro-segment by function** Historian access ≠ write to setpoints/commands. Least privilege per client.	**Browse-rate alerts on real servers** >100 Browse ops in one session ≠ historian behaviour. Probably recon.
Eliminate Anonymous auth in production Default to certificate-based for server-to-server. Strong policy on user/pass.	**GDS for certificate lifecycle** Manual cert management at scale is operationally unenforceable.	**Log all writes to *_PSP_*, *_LAHH, ESD_CMD_*** The OpcUaTrap detection model maps directly to production OPC UA monitoring.

If you do one thing this quarter — disable SecurityMode None on every OPC UA server you operate.

Information Classification: General

QUESTIONS?

THANK YOU

Contact: https://www.linkedin.com/in/juneda

OpcUaTrap — https://github.com/0xAJStrike/OpcUaTrap

Apache 2.0 — fork it, deploy it, build on it.